VIKASITA KERALAM

Role, Access and Designation

Business Requirements, RBAC Workflows and Information Architecture

A source-verified assessment of role management, module and action permissions, data access scope, the designation master and the organisational hierarchy that together determine who can see and do what across the Vikasita Keralam admin platform.

Document reference	VK-BRD-RBAC-001
Version	1.0
Date	13 November 2026
Classification	Internal — planning and approval
Prepared for	Product leadership, engineering, state administration
Basis	Static analysis of the repository at D:\Vikasita-Keralam

Status: Draft for approval. Findings describe the code as it exists today; recommendations are proposals that require product and engineering sign-off.

IN THIS DOCUMENT

PART A
Business requirements
Requirements catalogue, business objectives, rules and stakeholder scope.

PART B
Access workflows
Role creation, editing, assignment, permission evaluation and enforcement.

PART C
Information architecture
Settings navigation, organisational hierarchy and the entity model.

PART D
Scenarios and acceptance
User stories, acceptance criteria, risks, gaps and open decisions.

Prepared from direct inspection of the source repository. No application code, data or configuration was modified.

Contents

1 Document Control . . . 3
2 Executive Summary . . . 4
3 Business Context and Objectives . . . 5
4 Scope and Stakeholders . . . 6
5 Existing System Analysis . . . 7
6 Business Requirements . . . 10
7 Roles and Permission Model . . . 12
8 Designation Management . . . 14
9 Organisational Hierarchy . . . 15
10 Data Access Scope . . . 17
11 Role and Access Workflows . . . 18
12 Designation Workflows . . . 23
13 Information Architecture . . . 25
14 Entity Relationship Diagram . . . 26
15 Permissions and Designation Matrices . . . 27
16 User Stories . . . 29
17 Acceptance Criteria . . . 30
18 Risks and Dependencies . . . 31
19 Gap Analysis . . . 31
20 Recommendations . . . 32
21 Open Decisions . . . 33
22 Appendix — Source Code References . . . 34

How to read the requirement tables

Requirement IDs are stable and should be quoted in tickets. The Source column names the file or symbol that evidences the row; where a row is a proposal, the source describes the closest existing behaviour and the status column says Proposed.

1 Document Control

This section records how the document was produced, which evidence standards were applied, and what the reader should treat as confirmed fact versus recommendation.

1.1 Version history

Version	Date	Author	Change
1.0	13 November 2026	Business Analysis and Solution Architecture	Initial issue following source-code analysis.

1.2 Purpose

Vikasita Keralam is a citizen-facing welfare and party-operations platform with a desktop administrative workspace. Access to that workspace is currently governed by a client-side prototype: roles, designations, users and location masters are authored in the browser and persisted in local storage. Before the platform moves to production, the programme needs one agreed description of how access is meant to work, what has actually been built, and where the two diverge. This document provides that description and the requirements needed to close the gap.

1.3 Intended audience

- **Product leadership** — to approve the permission model, the designation model and the release scope.
- **Engineering** — to implement server-side authorisation, persistence and audit against a single specification.
- **State administration** — to confirm which organisational posts may create roles, assign roles and see data beyond their own unit.
- **Quality assurance** — to derive test cases from the acceptance criteria in Section 18.

1.4 Scope

In scope: role definition and lifecycle, module and action permissions, data access scope, designation master, organisation levels and hierarchy, user-to-role, user-to-designation and user-to-location assignment, and the navigation structure that exposes them. Out of scope: citizen-facing eligibility, schemes, applications processing, helpdesk operations and mobile screens, except where they consume a permission or a designation.

1.5 Source-code analysis methodology

The repository was read directly. Entry points were located from the TanStack route tree, then each screen was traced to the data modules and helper functions it imports. Every functional claim in this document is tied to a named file and symbol in Section 23. Where a behaviour could not be located, the document says so explicitly. No application code, data or configuration was modified.

1.6 Evidence taxonomy

Every requirement and finding carries one of these status labels; they are not interchangeable.

Status	Meaning
Implemented	The behaviour exists and was verified in source code, including its data source and effect.
Partially Implemented	A working slice exists, but a rule, validation, guard or persistence step is missing.
UI Only	The interface exists and behaves convincingly, but there is no durable data layer or server enforcement behind it.
Not Implemented	No corresponding implementation was found in the repository.
Proposed	A recommendation that requires approval; it is not a description of current behaviour.

1.7 Assumptions and limitations

- The repository is a front-end prototype. There is no database, no API service and no server-side session store; conclusions about persistence refer to browser local storage.
- Live usage counts, audit history and production role assignments cannot be observed from source code. Where a figure is a seeded or generated value, it is labelled as such.
- Organisational counts (regions, districts, mandalams) are reported exactly as configured in code. They are not asserted to be the officially notified structure.
- Screens outside the Settings workspace are referenced only where they consume a permission or a designation.

2 Executive Summary

Vikasita Keralam already has the shape of a complete access-management product: a role library, a permission matrix over seven modules, four data-access scopes, a designation master keyed to organisation level, a location master that mirrors the party hierarchy, and user records that carry a role, a designation and a set of location assignments.

What it does not yet have is a boundary. Every rule is authored and evaluated in the browser. A session is a JSON object in local storage with an eight-hour expiry and a hard-coded role of STATE_ADMIN. Roles, designations, users and overrides are stored in local-storage keys, and the shared access evaluator carries an explicit comment that it is intended for server-side enforcement “once an API exists”. Consequently the platform can demonstrate granular access control but cannot yet enforce it.

That distinction matters commercially as well as technically. The programme intends to delegate administration to regional, district, mandalam, area and booth functionaries. Delegation is only safe when three separate concepts are kept apart: the **role** that grants module and action permissions, the **designation** that records a party post, and the **data access scope** that bounds which records a person may see. The current implementation blurs the first and second by auto-generating a system role for every designation, which means a party post can silently carry permissions.

The recommended path is not a rebuild. It is to freeze the model described here, move evaluation and persistence to the server, remove the designation-to-role shortcut, and add an audit trail. Sections 20 and 21 set out the gaps and the sequence.

2.1 Position at a glance

Dimension	Current state
Permission modules	7 modules covering schemes, users, applications, requests, applicant profiles, roles and designations
Permission actions	29 discrete actions; 21 of them declare prerequisite chains that are enforced in the UI
Data access scopes	4 defined (own records, below my level, same level peers, above my level); 3 exposed in the create and edit flows
Designations	30 legacy register entries across 9 levels, plus 32 seeded master records across 6 role levels
Organisation levels	6 role organisation levels and 7 assignment levels; the two lists are not identical
Hierarchy configured	1 state, 3 regions, 14 revenue districts; the 30 organisational districts exist as a mapping, not as hierarchy nodes
Users	Managed in the browser only; a single assigned role per user; seeded counts are demonstrative
Server-side enforcement	None. No API, middleware, database or row-level filter exists in the repository
Audit of access changes	Not implemented. An unrelated operational activity log exists for issues and applications

2.2 What this means for the business

- **Delegation is currently unsafe.** Any signed-in administrator can create a role with any permission and assign it, because no server checks the actor and the delegation policy table only recognises two actors.

- **Visibility cannot be promised.** Data-access scope is stored per module but never applied to a query, so “below my level” and “same level” currently change nothing outside the settings screens.
- **Designation and permission are conflated.** Twenty-two auto-generated designation roles mean a party post can arrive with scheme and application permissions attached.
- **The model is otherwise sound.** The entity set, scope vocabulary and matrix structure are coherent and can be retained once enforcement moves server-side.

3 Business Context and Objectives

3.1 Why centralised role and access management is needed

The platform serves two very different populations. Citizens interact with eligibility checks, schemes and applications; party functionaries operate an administrative workspace that verifies documents, supports applications, routes helpdesk requests and maintains worker records. The second population is large, geographically distributed and organised in a hierarchy, and it changes frequently after organisational reviews. Access therefore has to be administered by people who are close to the work, without giving any one of them control of the whole platform.

Today that administration happens in a single settings workspace used by a state-level administrator. That is adequate for a prototype and inadequate for production: it concentrates power, cannot express delegation, and provides no record of who granted what.

3.2 Business objectives

#	Objective	Success measure
O1	Prevent unauthorised access to administrative functions	Every admin route and data call rejects an actor without the required module and action permission, on the server.
O2	Control which modules a user can open	A user without *view* on a module cannot reach its route, list or detail screen, including by direct URL.
O3	Control which actions a user may perform inside a module	Create, edit, delete, assign and respond are independently grantable and independently enforced.
O4	Restrict data visibility by organisational assignment	List and detail queries return only records inside the actor’s permitted scope and location units.
O5	Let authorised administrators create custom roles	A delegated administrator can define a role within their own permission ceiling and no higher.
O6	Support designation assignment by organisational level	The designation list offered to a user is filtered to the selected level, and only active designations appear.
O7	Keep designation and system permission separate	Assigning or changing a designation never changes a user’s effective permissions unless an explicit rule says so.
O8	Make access management auditable	Every create, edit, assignment and revocation of a role, designation or permission produces an immutable audit record.

3.3 Design principles

- **Deny by default.** Absence of a permission is a denial, not an implicit allowance.
- **Server decides.** The interface may hide what a user cannot do, but the server must refuse it.
- **Least privilege.** A role starts empty; permissions are added deliberately.
- **Separation of concerns.** Organisation level, designation, role and data scope are four different things and must be stored and edited separately.
- **No silent escalation.** An administrator cannot grant a permission they do not themselves hold.
- **Legible to administrators.** Every screen states which level, designation and role is being applied, and what that combination permits.

4 Scope and Stakeholders

4.1 Capabilities examined

Each capability below was traced from a route or component to its data module. The right-hand column states the strongest claim the code supports.

Capability	Primary location	Evidence status
Role library, create, edit, duplicate, delete	RoleAccessSettings.tsx, admin.settings_.new-role.tsx	UI Only
Module and action permission matrix	party-workers.ts, RoleAccessSettings.tsx	Implemented as client configuration
Prerequisite and cascade rules	permissionPrerequisites, togglePermission	Implemented
Data access scope per module	role-management.ts, new-role.tsx	Partially Implemented
Designation master	RoleAccessSettings.tsx, role-management.ts	Partially Implemented
Organisation levels and locations	RoleAccessSettings.tsx, admin-dashboard-metrics.ts	Partially Implemented
User creation and editing	admin.settings_.new-user.tsx	UI Only
Role assignment	admin.settings_.assign-role.tsx, RoleAccessSettings.tsx	UI Only
Server-side authorisation	not found	Not Implemented
Access audit trail	not found	Not Implemented

4.2 Explicitly out of scope

- Citizen-facing eligibility questionnaire, scheme directory and application submission.
- Matched-scheme results, document verification workflow and helpdesk case handling, except where they consume a permission.
- Party-worker directory, leaderboard and volunteer modules, except as data sources for user records.
- Desktop admin dashboard metrics, mobile preview rendering and the statewide communications surfaces.
- Any change to notification content, branding or translation strings.

4.3 Actors found in the implementation

The system does not model a rich set of actors. Two enumerations exist and neither matches the organisational vocabulary used in the interface.

Actor construct	Values	Where defined	Practical effect
Session role	STATE_ADMIN (single literal)	admin-auth.ts	Every signed-in administrator is treated as a state administrator.
ActorRole (delegation)	state_admin, party_worker	party-workers.ts	Only state_admin may delegate; every other actor is a plain user.
UI role selector	Admin, Sub Admin, Support Admin, Specific Role	assign-role route, new-user route	A label stored on the user record; it does not alter evaluation.
Seeded user categories	state_admin, district_admin, constituency_admin, local_body_admin, booth_admin, party_worker	RoleAccessSettings seeds	Demonstrative population counts only.
Party designations	30 entries	party-workers.ts	Organisational identity, not permission.

4.4 Four concepts that must stay separate

The single most important clarification in this document is that the following are different things, stored in different fields, and must not be conflated in the interface or the data model.

Concept	What it answers	Stored as	Grants permission?
Organisation level	Where in the hierarchy does this person sit?	orgLevel on the user; level on a designation	No
Designation	What party post does this person hold?	designationEn on the user; ManagedDesignation records	No, unless a role is attached
System role	Which modules and actions may this person use?	assignedRole on the user; ManagedRole records	Yes
Data access scope	Whose records may this person see?	dataAccess and scopedPermissions on the role	Bounds the role; does not grant
Location assignment	Which units does this person operate over?	regionEn, orgDistrictEn, mandalamEn, areaEn, boothEn on the user	No, but bounds every scope

Decision required

The current code attaches a system role to most designations automatically. If the business agrees that a designation must never grant permission, that behaviour has to be removed rather than documented as a convention. See Section 20, gap G-04.

5 Existing System Analysis

5.1 Architecture and runtime

The application is a React single-page application built with TanStack Router and TanStack Start, bundled by Vite and served through a Cloudflare Workers entry point. Styling uses Tailwind with a shared component library. There is no database client, no ORM, no API route collection and no authentication service in the repository. The server entry in src/server.ts only normalises server-side rendering errors; it does not authorise requests.

Layer	Present?	Evidence
React UI and TanStack route tree	Yes	src/routes/*, src/components/*
SSR entry / edge worker	Yes, rendering only	src/server.ts, wrangler configuration
API or service layer	No	No route handlers, controllers or fetchers for access data
Database or ORM	No	No client, schema, migration or query builder
Auth provider	No	Session created locally in admin-auth.ts
Server-side authorisation	No	No middleware, guard or policy engine
Audit store	No	No access-audit table, writer or viewer

5.2 Where the access domain lives

File	Responsibility	Key symbols
src/data/party-workers.ts	Canonical permission catalogue, presets, designations, delegation policy, scope vocabulary	permissionModules, permissionPrerequisites, rolePresets, partyDesignations, delegationPolicies, hasScopedAccess
src/data/role-management.ts	Managed role and designation types, storage adapters, scope keys, built-in role seeds	ManagedRole, RoleDraft, dataAccessOptions, loadManagedRoles, saveManagedRoles, builtInManagedRoles
src/components/admin/RoleAccessSettings.tsx	The whole settings workspace: four tabs, role CRUD, designation CRUD, user CRUD, bulk operations	RoleAccessSettings, ManagedDesignation, loadManagedUsers, saveManagedUsers
src/routes/admin.settings_.new-role.tsx	Full-page create and edit role with the permission matrix	dataAccessChoices, scopedPermissions, handleSave
src/routes/admin.settings_.new-user.tsx	Create and edit user with level, designation and location cascade	ORG_LEVEL_OPTIONS, DESIGNATIONS_BY_ORG_LEVEL, handleSave
src/routes/admin.settings_.assign-role.tsx	Bulk and single role assignment with a per-user permission grid	primaryMatrixRows, ROLE_OPTIONS
src/routes/admin.settings.tsx	Settings shell and tab routing	validateSearch, SettingsPage
src/lib/admin-auth.ts	Session create, read, expire, clear	createAdminSession, isAdminAuthenticated
src/data/users.ts	User shape and fallback resolvers for district, region and org district	AppUser, getUserOrgDistrict, getUserRegion
src/data/admin-dashboard-metrics.ts	Dashboard hierarchy used for organisational reporting	orgHierarchyData, OrgLevel

5.3 Authentication and session

Sign-in compares the submitted credentials against a hard-coded pair in the login route, then writes vk-admin-session to local storage. The stored object carries a username, the literal role STATE_ADMIN and an expiry eight hours ahead. The protected admin route reads that object on mount and redirects to the login page if it is absent, malformed or expired. There is no password hashing, no token, no refresh and no server verification. Clearing browser storage signs the user out.

Property	Value observed
Storage key	vk-admin-session
Session payload	username, role = STATE_ADMIN, expiresAt
Duration	8 hours from creation
Validation	JSON parse, role equality, expiry comparison
Server involvement	None

5.4 Persistence map

All durable state in the access domain is browser-local. The table lists the keys that were found and what each holds.

Storage key	Holds	Written by
vk-admin-session	Administrator session	admin-auth.ts
vk-managed-roles	Custom and edited role records	saveManagedRoles
vk-deleted-managed-role-ids	Tombstones for deleted roles	deleteManagedRole
vk-custom-organisation-levels	Administrator-created organisation levels	saveCustomOrganisationLevels
vk-custom-designations	Designation records created in the master	role-management adapters
vikasita_managed_designations_v1	The designation master actually rendered by the settings tab	saveManagedDesignations

Storage key	Holds	Written by
vk-designation-overrides	Renamed or re-levelled designations	role-management adapters
vk-hidden-designation-ids	Designations hidden from pickers	role-management adapters
vk-managed-desktop-users	Managed users, including assigned role and designation	saveManagedDesktopUsers
vk_newly_created_designation	One-shot hand-off after creating a designation (session storage)	designation save handler

Observation

Two different keys describe designations: vk-custom-designations and vikasita_managed_designations_v1. The Designation Master tab reads and writes the second; other adapters read the first. This is the root of the duplication described in Section 8.

5.5 Capability inventory

The following inventory records what each capability does, who can reach it, what it reads or writes, and what is missing.

Capability	Current behaviour	Access	Reads / writes	Status
View role library	Lists built-in and custom roles with level, user count and status chips	Any signed-in admin	Roles from seeds plus vk-managed-roles	UI Only
Create role	Form with name, description, levels, permission matrix and scope column	Any signed-in admin	Writes a ManagedRole	UI Only
Edit role	Same form pre-filled; built-in roles are read-only	Any signed-in admin	Rewrites the role, refreshes updatedAt	Partially Implemented
Duplicate role	Copies permissions and scopes under a new id	Any signed-in admin	Writes a new ManagedRole	UI Only
Delete role	Removes the record and writes a tombstone id	Any signed-in admin	vk-managed-roles, tombstones	Partially Implemented
Assign permission	Matrix of 7 modules by up to 5 actions, with prerequisite cascade	Any signed-in admin	permissions and scopedPermissions arrays	Implemented
Set data scope	Independent toggles per module; above-level hidden	Any signed-in admin	dataAccess map on the role	Partially Implemented
Designation master	List grouped by level, create, edit, enable, disable, delete	Any signed-in admin	vikasita_managed_designations_v1	Partially Implemented
Organisation location	Six sub-tabs for levels, regions, districts, mandalams, areas, booths	Any signed-in admin	In-memory state only	UI Only
Create user	Name, level, designation, location, role, optional overrides	Any signed-in admin	vk-managed-desktop-users	UI Only
Assign role	Single or bulk assignment with optional per-user permission grid	Any signed-in admin	assignedRole and overrides	UI Only
Enforce access	No route guard beyond session presence; no data filter	Not applicable	Not applicable	Not Implemented

5.6 Known limitations

- Permission checks are performed for presentation only. The shared evaluator is documented in code as intended for server-side use once an API exists.
- Location master edits are held in component state and are lost on reload; they do not persist to any key.
- The settings workspace exposes every capability to every signed-in administrator; there is no per-screen guard.
- Deleting a designation does not check whether users still reference it, leaving dangling designation names on user records.
- Duplicate designation names are accepted, including within the same organisation level.

- Changing a role does not invalidate the cached session or force a re-evaluation for affected users.

6 Business Requirements

The catalogue below is the normative requirement set for role, permission, designation and organisational access. Priority uses MoSCoW. Status describes today's code, not the requirement's importance. Source identifies the file or symbol that evidences the current state.

6.1 FR-01 Role management

ID	Requirement	Priority	Status	Source
FR-01.1	An administrator can view every role with its name, allowed levels, assigned user count and status.	Must	UI Only	RoleAccessSettings roles tab
FR-01.2	An administrator can create a role with a unique name, at least one assignment level and at least one permission.	Must	UI Only	saveRole validation
FR-01.3	An administrator can edit a custom role; built-in system roles are protected from edit and delete.	Must	Partially Implemented	RoleAccessSettings, system flag
FR-01.4	An administrator can deactivate a role so it remains visible but cannot be newly assigned.	Should	Partially Implemented	status field; assignment does not filter
FR-01.5	An administrator can assign a role to a user and revoke it.	Must	UI Only	assign-role route
FR-01.6	An administrator can view a role's detail, including which users hold it.	Should	Partially Implemented	assignedUsers counter
FR-01.7	Only an actor with role-management permission may create, edit or delete roles.	Must	Not Implemented	No server guard
FR-01.8	A duplicate role name is rejected case-insensitively.	Must	Implemented	saveRole duplicate check

6.2 FR-02 Permission management

ID	Requirement	Priority	Status	Source
FR-02.1	Permissions are granted per module and per action across the seven configured modules.	Must	Implemented	permissionModules
FR-02.2	Selecting a dependent action automatically selects its prerequisites.	Must	Implemented	withPrerequisites
FR-02.3	Removing a prerequisite removes every action that depends on it, transitively.	Must	Implemented	withoutDependentPermissions
FR-02.4	Permission groups are presented as readable matrix columns rather than raw keys.	Should	Implemented	primaryMatrixColumns
FR-02.5	Default permissions are seeded from role presets for the built-in roles.	Should	Implemented	rolePresets
FR-02.6	Existing role permissions can be updated and the change is reflected for holders.	Must	Partially Implemented	Persisted, but no session refresh
FR-02.7	Conflicting or mutually exclusive permissions are detected and blocked.	Could	Not Implemented	No conflict rule defined
FR-02.8	An actor cannot grant a permission that exceeds their own delegation authority.	Must	Partially Implemented	delegationPolicies constants only

6.3 FR-03 Data access control

ID	Requirement	Priority	Status	Source
FR-03.1	Record visibility is configurable per module using a defined scope vocabulary.	Must	Partially Implemented	dataAccessOptions
FR-03.2	Organisation-based restrictions are applied to list queries.	Must	Not Implemented	No query layer
FR-03.3	Restrictions are applied to detail views and direct links, not only lists.	Must	Not Implemented	No route guard
FR-03.4	Restrictions are applied in APIs and backend queries.	Must	Not Implemented	No API
FR-03.5	The effective policy is deny-by-default when no scope is configured.	Must	Proposed	hasScopedAccess returns false without a grant

6.4 FR-04 Designation management

ID	Requirement	Priority	Status	Source
FR-04.1	An administrator can view the designation master grouped by organisation level.	Must	Implemented	Designation Master tab
FR-04.2	An administrator can create a designation with a name and organisation level.	Must	Partially Implemented	handleSaveDesignation
FR-04.3	An administrator can edit a designation's name, level and parent.	Should	Implemented	handleSaveDesignation
FR-04.4	An administrator can activate or deactivate a designation.	Should	Implemented	handleToggleDesignationStatus
FR-04.5	Designations are associated with exactly one organisation level and ranked within it.	Must	Implemented	rank derivation
FR-04.6	Designation pickers offer only active designations for the selected level.	Must	Implemented	activeDesignations filter
FR-04.7	Duplicate designation names within a level are rejected.	Should	Not Implemented	Name-only validation
FR-04.8	A designation cannot be deleted while users are assigned to it.	Should	Not Implemented	No dependency check

6.5 FR-05 Organisational access

ID	Requirement	Priority	Status	Source
FR-05.1	Users are assigned to one organisation level from a controlled list.	Must	Implemented	ORG_LEVEL_OPTIONS
FR-05.2	Users are assigned to one or more organisational units (region, district, mandalam, area, booth).	Must	Implemented	new-user location cascade
FR-05.3	Reporting relationships are resolvable from the assignment.	Should	Not Implemented	No parent-user link
FR-05.4	Eligible data visibility is derived from level and location assignment.	Must	Not Implemented	No evaluator at query time
FR-05.5	Multiple assignments are supported and their union is used for visibility.	Should	Partially Implemented	Multi-select stored; union not applied

6.6 FR-06 User assignment

ID	Requirement	Priority	Status	Source
FR-06.1	A user record carries exactly one system role.	Must	Implemented	assignedRole
FR-06.2	A user record carries exactly one designation, filtered by level.	Must	Implemented	designationEn plus validation
FR-06.3	A user record carries an organisation level.	Must	Implemented	orgLevel
FR-06.4	A user record carries one or more organisational locations.	Must	Implemented	regionEn, orgDistrictEn, mandalamEn, areaEn, boothEn
FR-06.5	Changing the organisation level clears an incompatible designation.	Must	Implemented	level change handler
FR-06.6	Reassigning a user to another unit preserves role and designation and is auditable.	Should	Partially Implemented	Reassignment works; no audit
FR-06.7	Revoking a role takes effect immediately for the affected user.	Must	Not Implemented	No session invalidation

6.7 Requirement summary

Group	Requirements	Implemented	Partially	UI only	Not implemented	Proposed
FR-01 Role management	8	1	3	3	1	0
FR-02 Permissions	8	4	2	0	1	0
FR-03 Data access	5	0	1	0	3	1
FR-04 Designations	8	4	2	0	2	0
FR-05 Organisation	5	2	1	0	2	0
FR-06 User assignment	7	4	1	0	2	0
Total	**41**	**15**	**10**	**3**	**11**	**1**

7 Roles and Permission Model

7.1 Module catalogue

Seven modules are configured. The action set is deliberately uneven: schemes distinguishes list from detail visibility, requests uses assign and respond rather than edit, and users carries an additional team-visibility action. Any requirement that assumes uniform create-read-update-delete across modules is therefore wrong.

Module	Label in UI	Actions	Count
schemes	Schemes	view_list, view_details, create, edit, delete	5
party_workers	Users	view, create, edit, delete, view_teams	5
applications	Applications	view, create, edit, delete	4
help_desk	Request	view, assign_team_member, respond_reply	3
applicant_profile	Applicant Profile	create, edit, view, delete	4
roles	Role and Access	view, create, edit, delete	4
designations	Designation	view, create, edit, delete	4

7.2 Prerequisite and cascade rules

Twenty-one actions declare prerequisites. The UI enforces them in both directions: granting a dependent action silently grants its prerequisites, and revoking a prerequisite removes every transitive dependent. This is the strongest implemented rule set in the domain and should be preserved when evaluation moves to the server.

Dependent action	Requires	Direction
schemes.view_details	schemes.view_list	Grant implies prerequisite
schemes.create / edit / delete	view_list, view_details	Grant implies prerequisites
party_workers.create / edit / delete	party_workers.view	Grant implies prerequisite
party_workers.view_teams	party_workers.view	Grant implies prerequisite
applications.create / edit / delete	applications.view	Grant implies prerequisite
help_desk.assign_team_member / respond_reply	help_desk.view	Grant implies prerequisite
applicant_profile.create / edit / delete	applicant_profile.view	Grant implies prerequisite
roles.create / edit / delete	roles.view	Grant implies prerequisite
designations.create / edit / delete	designations.view	Grant implies prerequisite

7.3 Role presets

Seven presets seed the built-in library and the designation-derived roles. They are starting points, not enforced templates.

Preset	Intended holder	Seeded permissions
State Admin	Statewide administration	Schemes view and edit, users full except delete, applications view/create/edit
District Admin	District operations	Schemes view only, users view/create/edit plus teams, applications view/create/edit
Constituency Admin	Constituency operations	Same shape as District Admin
Local Body Admin	Local body follow-up	Schemes view, users view/create, applications view/create/edit
Booth Admin	Booth-level assistance	Schemes view, users view, applications view/create
User (party worker)	Everyday worker	Schemes view, applications view/create
Custom	Any bespoke role	None; the administrator starts from the current selection

7.4 Built-in and protected roles

The library combines preset-derived access roles with the designation-derived roles described in 7.5. A system flag marks built-ins as protected: create, edit and delete are refused, with a small number of exceptions for the state administrator, sub-administrator and support administrator roles so that the top of the hierarchy remains operable. Protection is a UI rule; no server enforces it.

7.5 Role and designation coupling

This is the most consequential design decision in the current implementation. For every designation whose level belongs to the six role levels, the platform synthesises a system role with the same name and the permissions of the matching preset. Twenty-two designations fall inside those six levels, so twenty-two roles appear in the library that nobody consciously created.

> **Why this conflicts with the requirement**
> A party post is an organisational fact. A system role is a permission grant. Deriving one from the other means appointing a Mandalam Secretary can change what a person may see and edit without anyone deciding that it should. The requirement in FR-06 and business rule BR-01 is that designation never grants permission. The current behaviour must be removed or explicitly approved as an exception.

7.6 Delegation policy

A delegation policy table defines what an actor may hand out. It recognises only two actors: state_admin, which may grant anything statewide including access management, and party_worker, which may grant nothing. District, mandalam and booth administrators exist as labels and as seeded user categories but have no delegation policy, so delegated administration cannot be expressed today.

Actor	Statewide delegation	Access management	Grantable actions
state_admin	Yes	Yes	All (wildcard)
party_worker	No	No	None
Any other label	Undefined	Undefined	Undefined; falls back to no delegation

8 Designation Management

8.1 Three designation registers

Designations are stored three times, in three shapes, for three different consumers. This is not a stylistic issue: the registers disagree on naming, and only one of them is edited by the Designation Master.

Register	Location	Shape	Count	Consumed by
Legacy designation catalogue	partyDesignations in party-workers.ts	id, en, ml, level	30 across 9 levels	Designation-derived roles, assignment flows
Seeded master	DEFAULT_DESIGNATIONS_BY_LEVEL in RoleAccessSettings.tsx	level to name list	32 across 6 levels	Designation Master tab, persisted to vikasita_managed_designations_v1
User form map	DESIGNATIONS_BY_ORG_LEVEL in admin.settings_.new-user.tsx	level to name list	32 across 6 levels	Designation dropdown in Create User

The master and the user form contain the same 32 names, duplicated as separate constants. The legacy catalogue uses different conventions: at Mandalam level it offers “Mandalam President” and “Mandalam Secretary” where the master offers “President” and “Secretary”. Until one register is authoritative, a designation chosen in one screen may not match the designation reported in another.

8.2 Designation record

Field	Type	Required	Behaviour
id	String	Yes	Generated as DESIG- for new records; seeded records use DESIG-001 style ids
name	String	Yes	Trimmed; no uniqueness check, including within the same level
orgLevel	String	Yes	One of State, Region, Organisational District, Mandalam, Area, Booth
parentDesignation	String	No	Must match the name of another designation at the same level to affect rank
rank	Number	Derived	Parent rank plus one; otherwise 1, or 2 when a parent was named but not found
status	Active or Disabled	Yes	Disabled records remain visible in the master but are excluded from pickers

8.3 Lifecycle

Creation opens a dialog, captures a name, a level and an optional parent, computes the rank, and prepends the record to the master. Editing replaces name, level and parent and recomputes rank. Enable and disable toggle status in place. Delete removes the record after a confirmation prompt. A successful save also writes a one-shot session value so the caller can preselect the new designation when returning to a user form.

8.4 Validation as implemented

Rule	Implemented	Note
Name is mandatory	Yes	Error toast; the dialog stays open
Name is trimmed	Yes	Surrounding whitespace removed
Name is unique within a level	No	Duplicates are accepted
Name is unique across levels	No	Duplicates are accepted
Organisation level is valid	Yes	Chosen from a fixed list
Parent exists at the same level	Partial	If not found, rank silently becomes 2
Deletion checks assigned users	No	Users keep a stale designation string
Disabled designations excluded from pickers	Yes	Filtered against active records

8.5 Impact of change

- Renaming a designation does not rewrite the designation string already copied onto user records, so historical users appear to hold a designation that no longer exists.
- Changing a designation’s level does not revalidate the users assigned to it; they remain on the old level with a designation now belonging to another.
- Because designation-derived roles exist, a rename can also change role names that users still reference by id.
- Disabling a designation prevents new assignment but does not revoke it from existing holders.

9 Organisational Hierarchy

9.1 Hierarchy as configured

The dashboard hierarchy data stops at revenue district. Organisational districts, mandalams, areas and booths are not nodes in that tree: the org districts exist as a lookup that maps a revenue district to one to three organisational districts, and the lower levels exist only inside the settings location master, which holds them in memory.



Organisation level is a position in this tree. Designation is a party post attached to one level. Neither implies a system role.

Figure 9.1 — Organisation hierarchy and the strength of each level in the current code

Level	Count in code	Source	Status
Kerala State	1	orgHierarchyData	Implemented
Region	3	orgHierarchyData, partyRegions	Implemented
Revenue District	14	orgHierarchyData, geo module	Implemented
BJP Organisational District	30	ORG_DISTRICTS_MAP in users.ts	Partial: mapping only
Mandalam	140 assumed	scopeTypeOptions maps label to assembly constituency	Partial: no node data
Area	Configurable	Location master state	Not modelled
Booth	Configurable	Booth directory generator	Not modelled: placeholder

9.2 Two level vocabularies

Two different level enumerations are in use, and they do not agree. Role assignment levels describe geography and administrative units; role organisation levels describe the party structure. The interface mixes both, which is why the same screen can offer “District” and “Organisational District” as if they were comparable.

Role organisation levels (6)	Assignment levels (7)	Difference
State	State	Aligned
Region	(absent)	Regions exist for roles but cannot be chosen as an assignment level
Organisational District	District	Same word, different concept
Mandalam	Assembly Constituency	Party structure versus electoral geography
(absent)	Local Body	Not a party level
(absent)	Ward	Not a party level
Area	(absent)	Areas have no assignment level
Booth	Booth	Aligned

The consequence is practical. A role can be restricted to the six party levels, while a user is described with one of seven geographic or administrative levels. The two lists are matched only by string comparison in a few places, so a user at "District" is not automatically recognised as being at "Organisational District".

9.3 Geographic versus organisational

Kerala has 14 revenue districts. The party organises across 30 organisational districts, several of which split a revenue district. Both concepts are real and both are needed, but they answer different questions: revenue district is where a citizen lives and where government schemes are administered; organisational district is which party unit a functionary reports to. The data model should carry both, with the organisational district linked to its parent revenue district rather than replacing it.

9.4 Missing structure

- **Mandalam.** The label is mapped to assembly constituency for scoping, but there is no record set of 140 mandalams, no parent link and no identifier.
- **Area and Booth.** Both are created ad hoc in the location master and discarded on reload. The booth directory generates six booths per constituency as placeholder data and must not be presented as official.
- **Reporting lines.** No user-to-user reporting relationship exists, so "below my level" cannot be resolved to specific people.
- **Unit identifiers.** Location assignments are stored as display names joined into a string, not as references to unit records.

10 Data Access Scope

10.1 The four scopes

Four scopes are defined. Their meanings are stated in the interface and in code comments, but no query applies them.

Scope id	Label	Intended meaning	Exposed in create/edit
own_records	Own Records	Records created by, or explicitly assigned to, the current user	Yes
below_level	Below My Level	Records belonging to organisationally subordinate users or units	Yes
same_level	Same Level — Peers	Records belonging to users at the same relevant organisational level	Yes
above_level	Above My Level	Records belonging to organisationally superior users or units	No: filtered out

> **Important**
> The above-level scope is defined in the data model and has translations, but both the create-role and create-user screens remove it from the choices. It cannot be granted through the interface today. Either the scope is removed from the vocabulary or the control is restored with a clear policy on when upward visibility is legitimate.

10.2 How scope is selected and stored

Scope is configured per module, not per role. Each module row in the permission matrix carries its own set of scope toggles, and every action within that module can be granted independently at each selected scope. The combination is stored as a flat string key of the form module.scope.action, for example applications.below_level.edit. A separate dataAccess map records which scopes are enabled for each module, and a scopedPermissions array records the individual keys.

Aspect	Implementation
Granularity	Module, then scope, then action
Selection	Independent toggles; multiple scopes may be combined for one module
Key format	module.scope.action
Storage	dataAccess map plus scopedPermissions array on the role record
Default for a new role	All supported scoped keys selected when the administrator uses “select all”
Enforcement	None at query time

10.3 Semantics that remain undefined

The following questions cannot be answered from the code. Each needs a business decision before server-side enforcement is written.

Question	Why it matters	Current answer
Does “below” mean all descendants or only direct reports?	Determines whether a state administrator sees a booth worker through four levels	Not defined
Do “peers” mean the same unit or everyone at that level statewide?	A peer scope could expose every district in Kerala	Not defined
Does “above” stop at the line manager or extend to the top?	Upward visibility is a sensitive capability	Not defined; scope not exposed
How are overlapping scopes combined?	Union would be permissive; intersection would be restrictive	Multiple scopes can be selected; combination rule absent
Does scope apply equally to read, edit, delete, export and approve?	Editing another unit’s record may be acceptable where reading it is not	One scope set per module; no per-action scope distinction
How is a record attributed to a unit?	Scope needs an owner or unit on every record	No ownership field on access-controlled records

11 Role and Access Workflows

The four workflows below describe the current behaviour end to end. Each diagram is annotated with the point at which the process leaves the browser, because that is where every control currently stops.

11.1 Role creation

Creation is a full-page flow reached from the roles tab. The actor enters identity, chooses the levels at which the role may be held, then works through a matrix. Validation runs on save and blocks the commit if any of three conditions fail. A duplicate name is compared case-insensitively across existing roles, including protected ones.

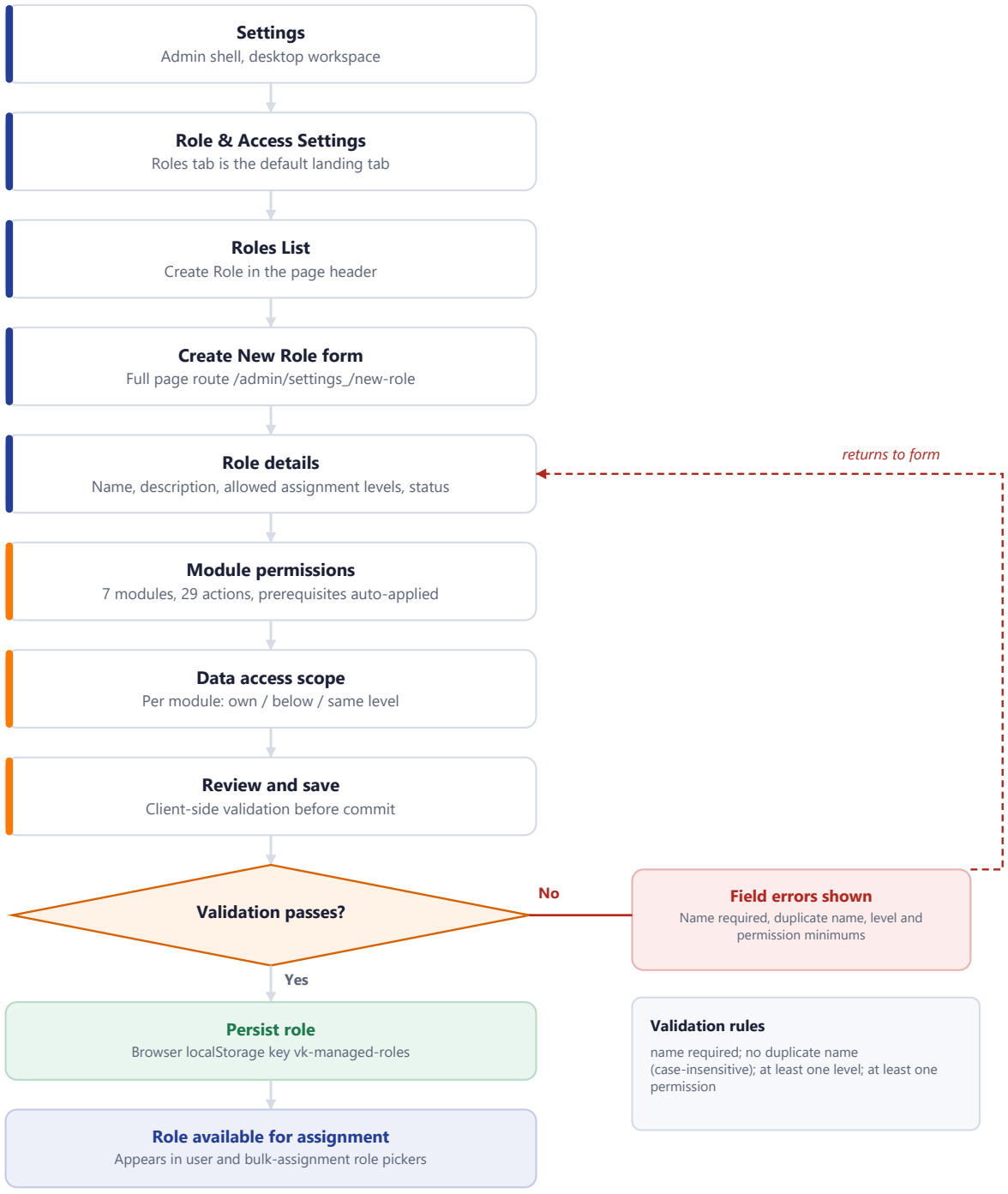


Figure 11.1 — Role creation workflow

Attribute	Detail
Actor	Any holder of a valid admin session; the session role is always STATE_ADMIN
Entry point	Settings, Role and Access Settings, Roles tab, Create Role
Preconditions	An active session; nothing else is checked
Inputs	Role name, description, allowed assignment levels, status, module permissions, data access scopes
Validation	Name required; name unique case-insensitively; at least one assignment level; at least one permission
Save behaviour	Written to vk-managed-roles with created and updated timestamps
Duplicate handling	Blocked by name; Duplicate copies an existing role under a new id
Postcondition	The role appears in role pickers and can be assigned immediately
Failure state	Inline field errors; the form stays open and no record is written

11.2 Role editing and its impact on holders

Editing is where an access-management design is most likely to fail quietly. A role change is persisted, but no session is invalidated, no cache is cleared and no notification is sent. A user who is signed in continues with the permissions that were resolved when their screen loaded. Until evaluation is server-side and stateless, this gap cannot be closed by the interface alone.

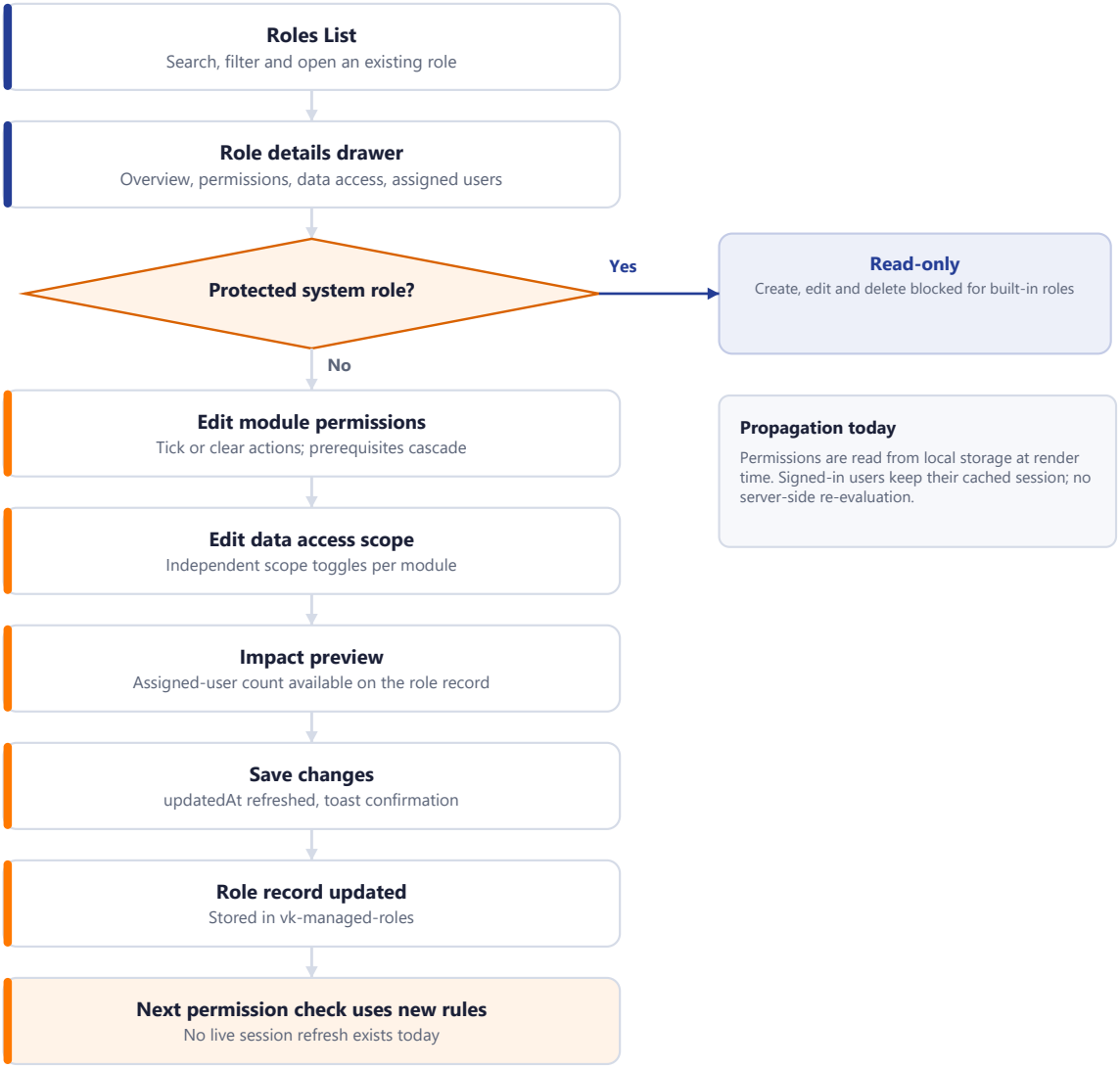


Figure 11.2 — Role editing workflow and the protection boundary

Rule	Implemented behaviour
Protected roles	Built-in roles refuse edit and delete; three top-level roles are exempt so administration remains possible
Permission propagation	The stored role is updated; nothing re-evaluates it for signed-in users
Assigned users	A count is held on the role record; it is not recomputed from the user list
Audit history	None. The record carries only createdAt and updatedAt
Concurrent edits	Last write wins; there is no version check

11.3 Role assignment

Assignment is single-role. The user record carries one assignedRole string; there is no membership table, so a user cannot hold two roles and there is no notion of a primary or secondary role. Bulk assignment exists and applies the same role to every selected user. The assignment screen also offers a per-user permission grid, which means an individual can be granted permissions that their role does not contain — an override that is stored on the user and invisible from the role record.

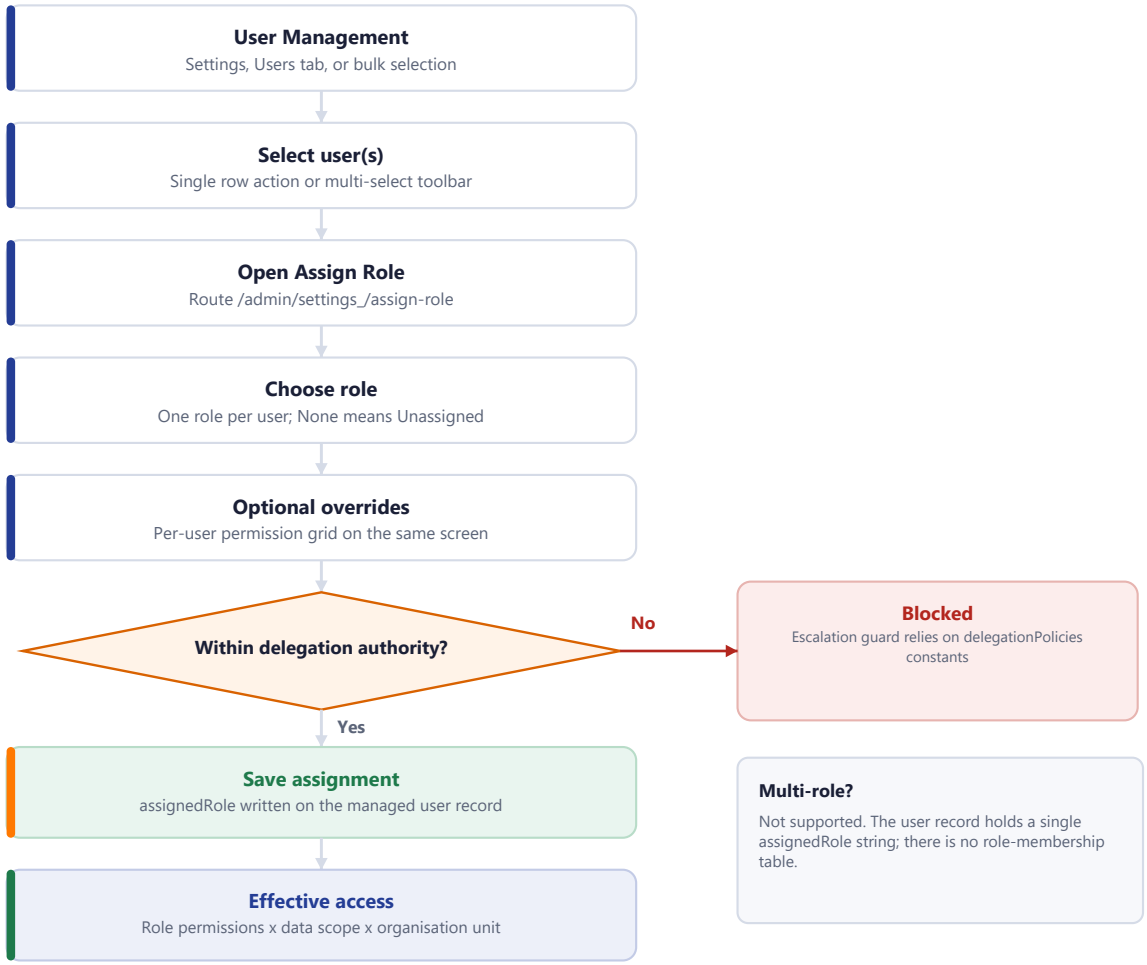


Figure 11.3 — Role assignment workflow

Open question for approval

Personal overrides break the statement “a role defines what a user may do”. Either overrides become a supported second mechanism with their own audit and review, or the grid is removed from the assignment screen. See Section 21, decision D-03.

11.4 Permission evaluation

The evaluation chain below is what a production system must perform on every request. In the current code only the session-presence check exists, and it happens once, on mount, in the browser. Steps three to eight are described in the data model and partially exposed in the interface, but they are never executed against a real record.

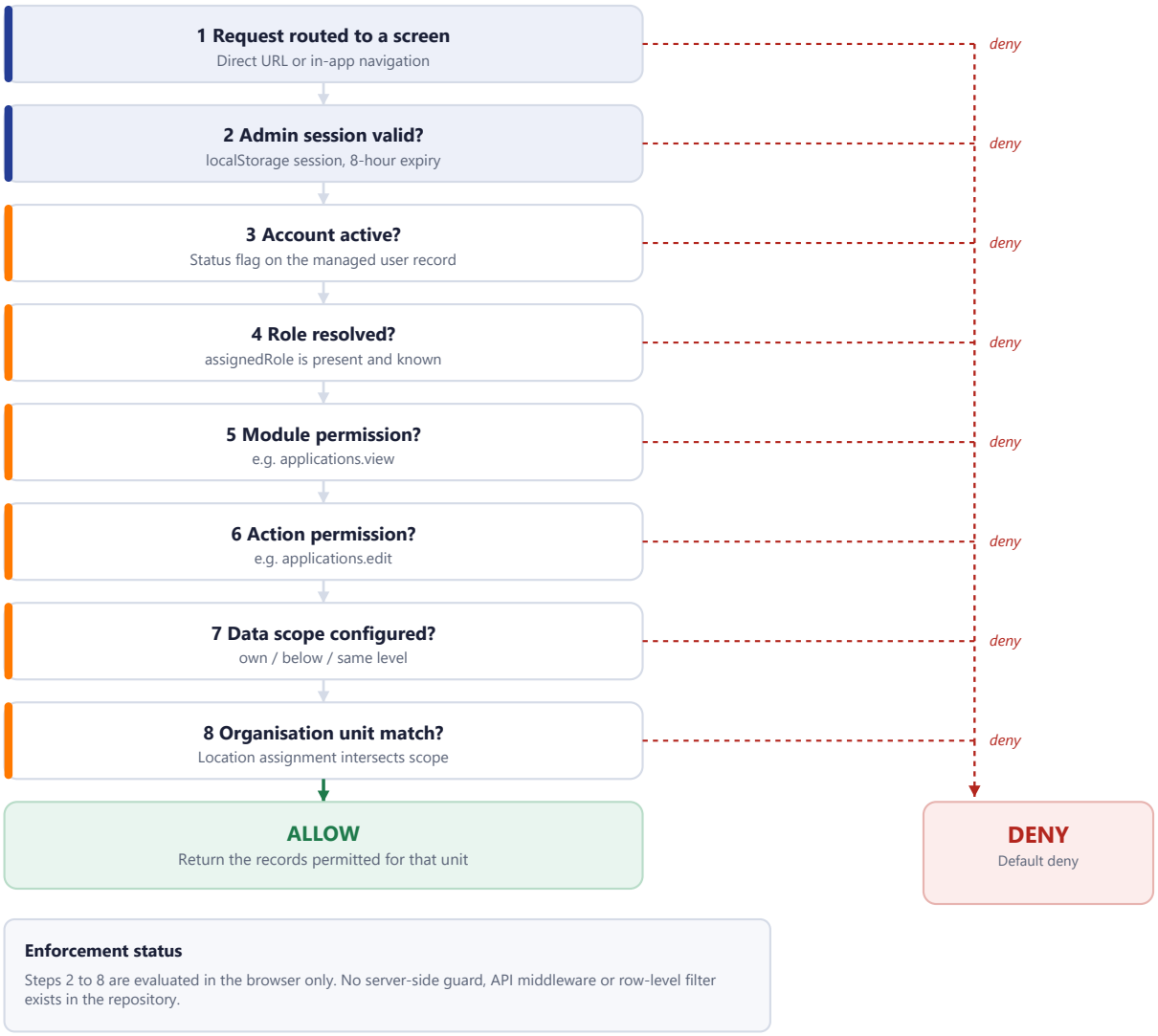


Figure 11.4 — Permission and data-access evaluation, with deny-by-default

Check	Implemented today	Required
Session present and unexpired	Yes, client-side	Yes, server-side
Account active	Field exists, not checked	Reject disabled users
Role resolved	String stored, not validated	Reject unknown or inactive role
Module permission	Not checked on route entry	Reject route and data call
Action permission	Not checked on handler	Reject mutation
Data scope configured	Stored, not applied	Default deny when absent
Organisation unit match	Not evaluated	Filter rows before return
Audit	None	Record allow and deny for sensitive actions

Negative scenarios that must be specified and tested: direct URL entry to a module without view permission; a crafted identifier for a record outside scope; an export that bypasses list filtering; an approval action on a record the actor may read but not approve; and a disabled role still held by a signed-in user.

12 Designation Workflows

12.1 Designation creation

The workflow is short and entirely local. Its weakness is validation depth rather than length: a name and a level are enough to create a record that immediately appears in every matching picker.

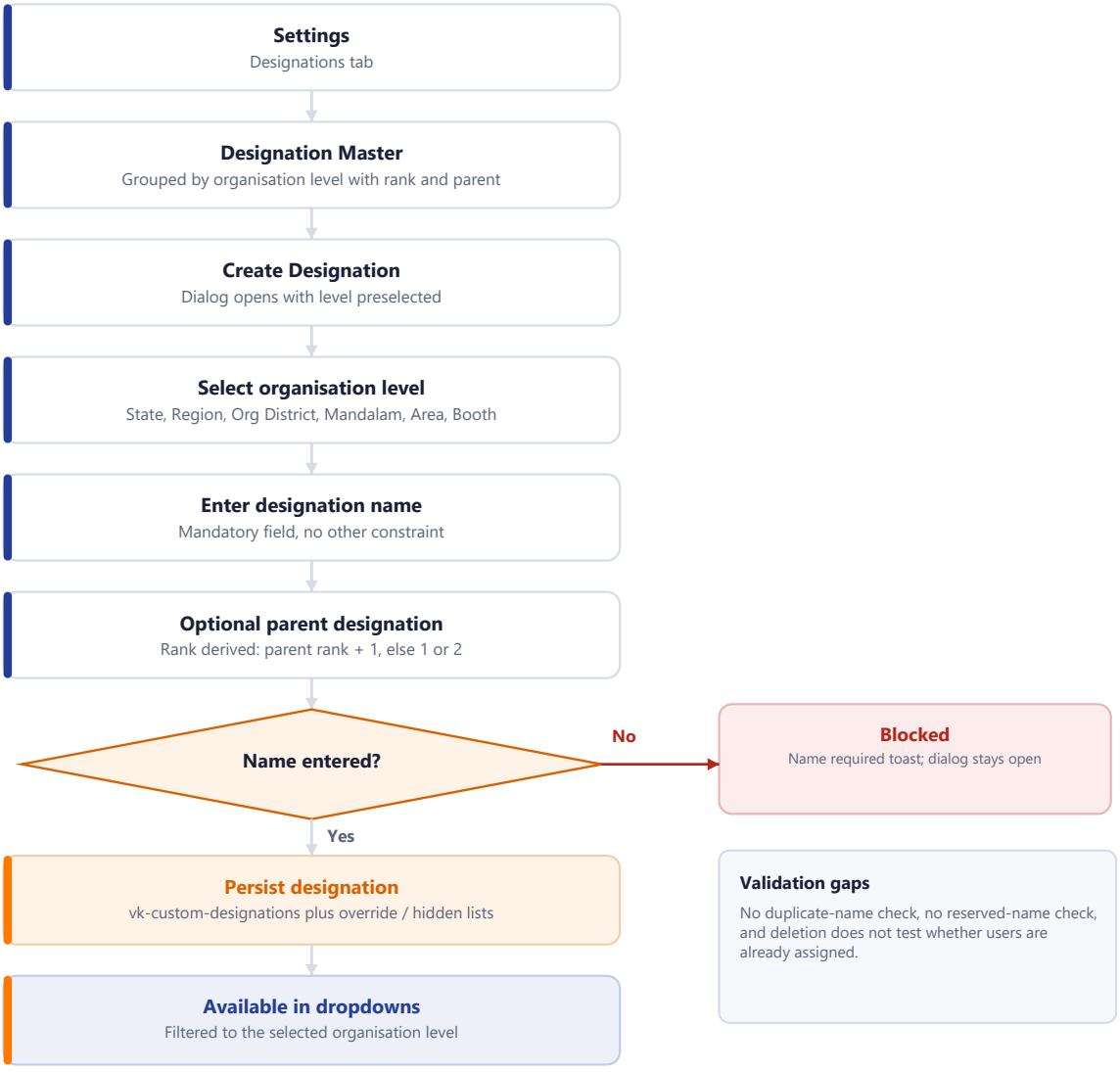


Figure 12.1 — Designation creation workflow

Attribute	Detail
Actor	Any holder of a valid admin session
Preconditions	None beyond the session
Required fields	Name and organisation level
Optional fields	Parent designation, used only to derive rank
Duplicate handling	Not validated; duplicates are accepted
Status handling	New records are Active; disable is a separate action
Postcondition	The designation appears in pickers for its level; a session hand-off value is written

12.2 Designation assignment to a user

Assignment happens inside the user form. The organisation level is chosen first and the designation list is filtered to it, which is the correct dependency order. A designation that does not belong to the selected level is rejected on save even if it was injected into the form. Changing the level afterwards clears the selection rather than silently retaining an invalid pairing.

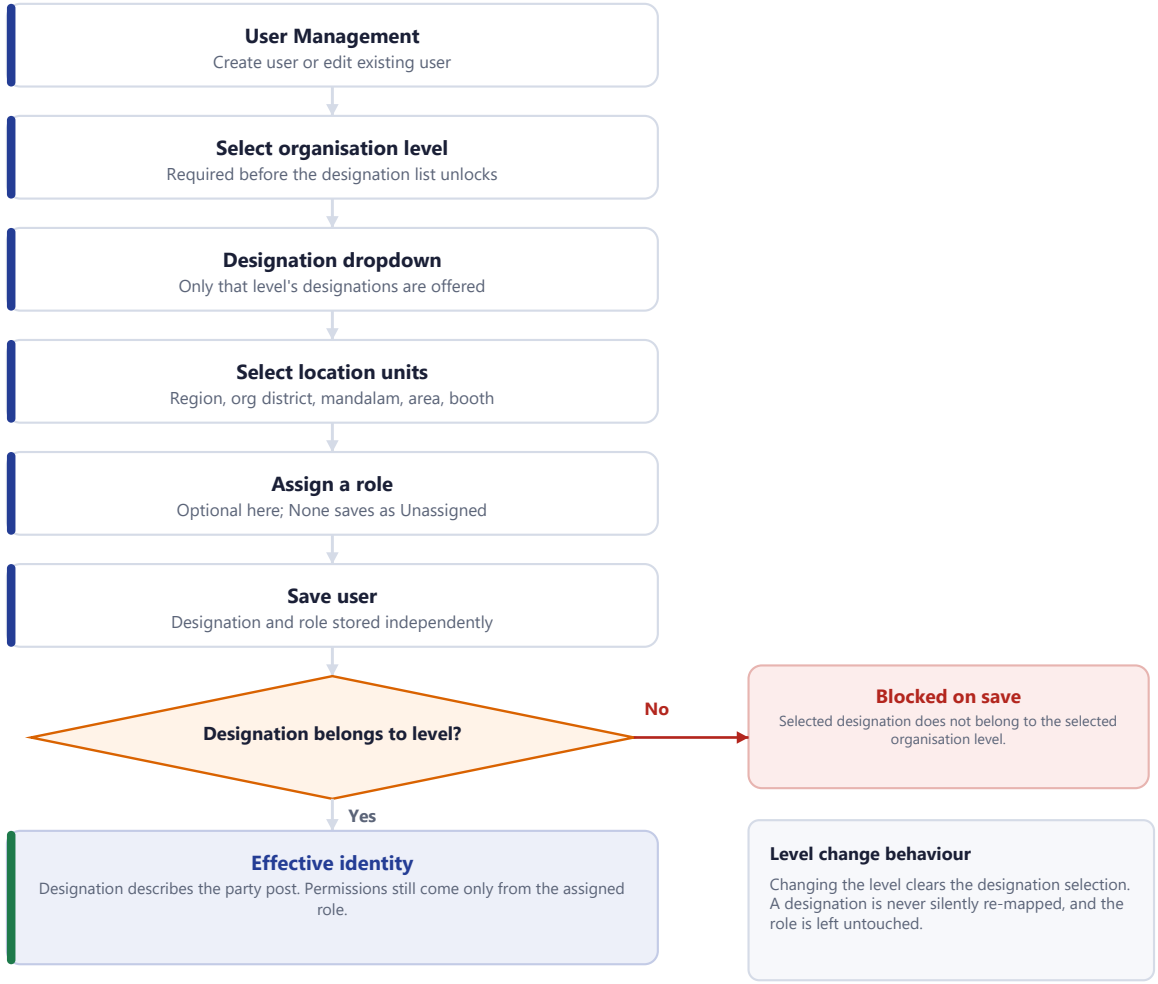


Figure 12.2 — Designation assignment workflow

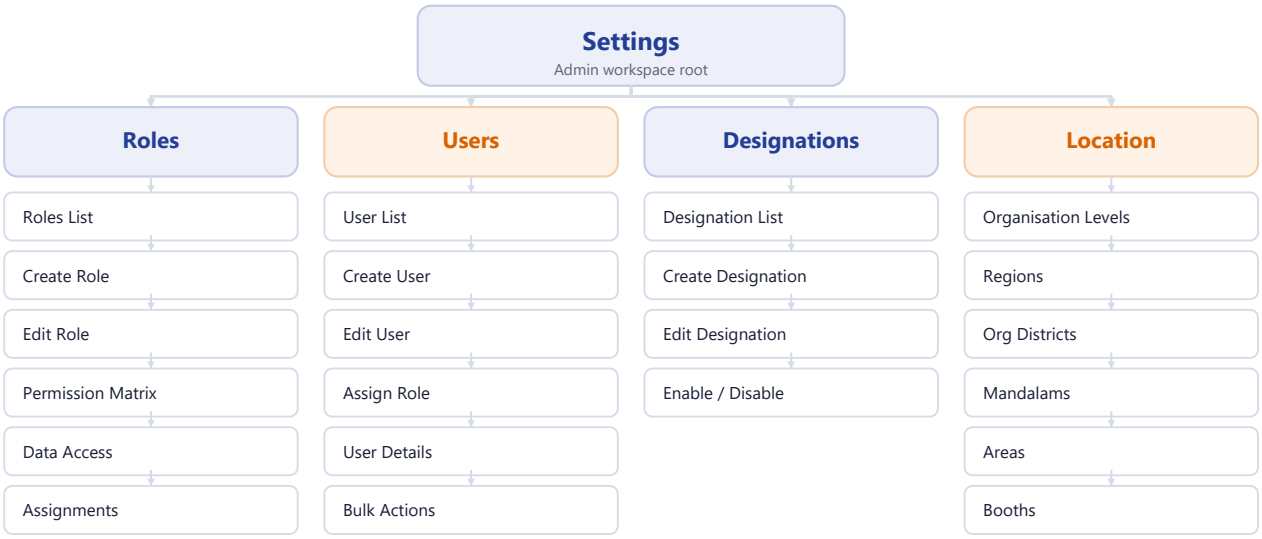
Behaviour	Implementation
Level before designation	The designation picker is disabled until a level is selected
Filtering	Active designations for the selected level only
Cross-level guard	Save is blocked with an explicit message if the pairing is invalid
Level change	Clears the designation selection
Role coupling	The role is chosen separately and is never derived from the designation in this form
Persistence	Designation is copied into designationEn and designationMl on the user record

Inconsistency to resolve

The Create User form does not use the Designation Master that the Designation tab edits. It reads a separate constant. Adding a designation in the master therefore may not make it available in Create User. See Section 20, gap G-05.

13 Information Architecture

The settings workspace is a single component with four tabs, reached from the admin shell. One tab, Roles, also owns full-page routes for create-role, create-user and assign-role. The result is a shallow structure with a small number of deep leaves, which is appropriate for the current scope but will not scale once delegated administrators need their own landing views.



All four tabs live in one component (RoleAccessSettings). Roles, Users and Designations persist to local storage; Location edits are in-memory only.

Figure 13.1 — Settings information architecture as implemented

Route	Component	Contents	Status
/admin/settings	SettingsPage	Shell with tab query parameter and sub-tab routing	Implemented
?tab=roles	RoleAccessSettings	Role list, table actions, drawers, bulk operations	Implemented
?tab=users	RoleAccessSettings	User list, filters, bulk assignment entry	Implemented
?tab=designations	RoleAccessSettings	Designation master grouped by level	Implemented
?tab=location	RoleAccessSettings	Levels, regions, districts, mandalams, areas, booths	UI Only
/admin/settings_/new-role	New role page	Full-page matrix with scope column	Implemented
/admin/settings_/new-user	New user page	Level, designation, location and role cascade	Implemented
/admin/settings_/assign-role	Assign role page	Bulk and single assignment with overrides	Implemented
/admin/settings_/user-details	User details page	Read view of a managed user	Implemented

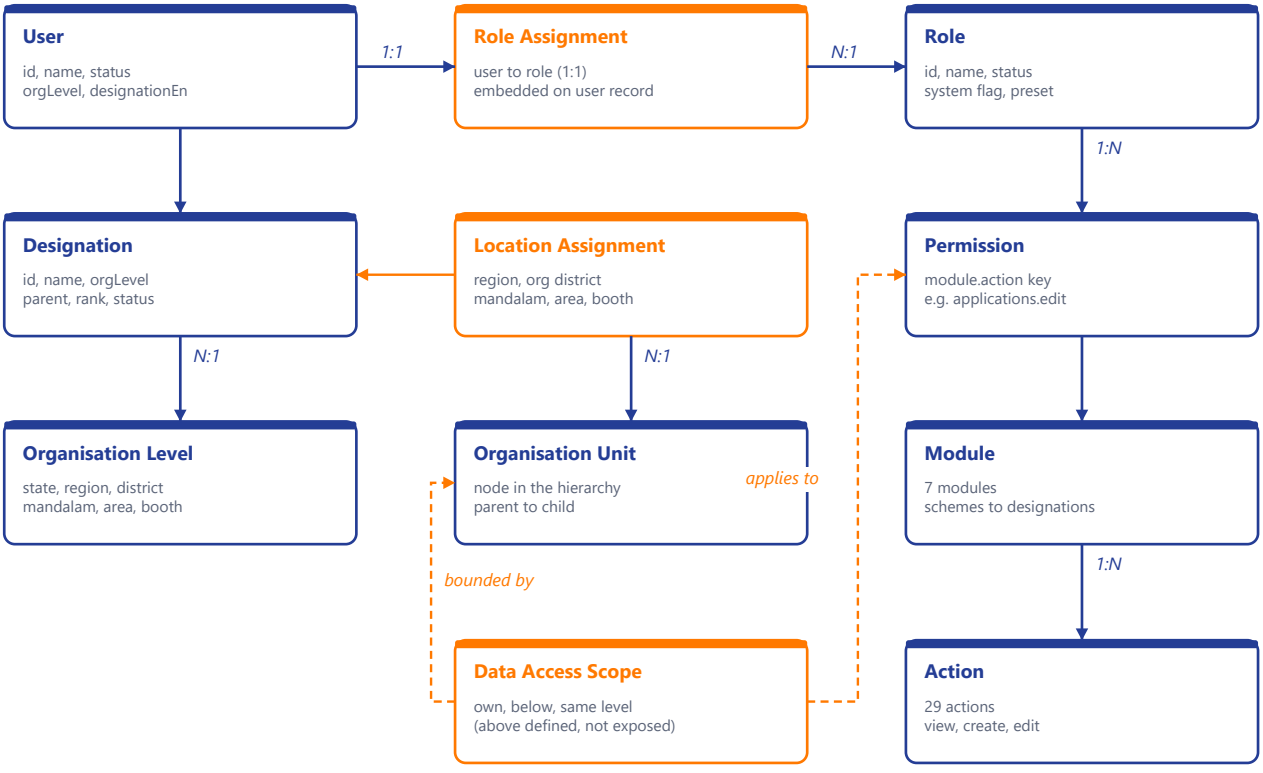
Three navigation gaps are worth noting. There is no route or screen for an organisation hierarchy editor, even though a hierarchy is displayed on the dashboard. There is no role-detail route: the drawer and the edit form are the only views. And there is no delegation console, so a regional administrator has no entry point even if the permission model were extended to support one.

Node in the target architecture	Exists?	Note
Settings, Role and Access Settings	Yes	Single component, four tabs
Roles List, Create, Edit	Yes	Create and edit are full-page routes
Role Details	Partial	Drawer only; no addressable route
Module Permissions	Yes	Matrix inside the role form
Data Access Permissions	Partial	Per-module scope column; above-level suppressed

Node in the target architecture	Exists?	Note
Role Assignments	Yes	Bulk and individual assignment
Designation Master, list, create, edit	Yes	Dialog based
Organisation Levels	Partial	Editable but memory-only
Organisational Locations	Partial	Regions to booths, memory-only
Hierarchy Relationships	No	Displayed on the dashboard, not editable
User Management, list, create, edit	Yes	User list plus full-page forms
Delegation console	No	Delegation policy exists only as constants

14 Entity Relationship Diagram

No database schema exists in the repository, so the model below is conceptual. Every entity corresponds to a TypeScript interface or a stored record that was actually found; no table or column name is invented. Cardinality reflects how the data is stored today, including the places where a proper relational structure is collapsed into a single field.



Audit Log (not implemented)

An access audit trail would record actor, target, before and after values, timestamp and source for role, permission, designation and assignment changes. No such table, writer or viewer exists in the repository.

Conceptual model. The repository has no database schema: entities reflect the TypeScript interfaces and local-storage records that actually exist.

Figure 14.1 — Role, permission, designation and organisation relationships

Entity	Purpose	Key fields	Relationships
User	A managed administrator or party functionary	id, name, status, orgLevel, designationEn, assignedRole	One role, one designation, many location assignments
Role	A named grant of permissions	id, name, status, system, presetId, permissions, dataAccess	Many permissions; held by many users

Entity	Purpose	Key fields	Relationships
Role Assignment	The link between a user and a role	assignedRole on the user	Collapsed; one to one in practice, many to one from roles
Permission	A single module.action grant	module, action, scopes	Belongs to a role; references a module and action
Module	A functional area	id, label, actions	One to many actions
Action	A permitted operation inside a module	id, label, prerequisites	Many to one module; declares prerequisites
Data Access Scope	The visibility bound for a module	scope id, module, enabled	Attached to a role; bounded by organisation units
Designation	A party post at one level	id, name, orgLevel, parent, rank, status	Many to one organisation level; one to many users
Organisation Level	A tier of the hierarchy	id, label, position	One to many designations and units
Organisation Unit	A node in the hierarchy	id, name, parent	Many to one parent; referenced by location assignments
Location Assignment	The units a user operates over	region, orgDistrict, mandalam, area, booth	Collapsed into five string fields on the user
Audit Log	A record of access changes	actor, target, before, after, timestamp	Not implemented

Two modelling decisions are visible in the diagram and both should be corrected before persistence is built. Role assignment is collapsed onto the user as a single string, which prevents multiple roles and prevents a query for “all holders of this role”. Location assignment is collapsed into five display-name strings, which prevents a stable reference to a unit and makes renames destructive.

15 Permissions and Designation Matrices

15.1 Module and action matrix

The matrix reports what the permission catalogue supports, not what any individual holds. Where an action is absent from the module it is marked Not Available; the dashboard-level actions that the business has discussed but which are not modelled are marked Not Confirmed and must not be assumed.

Module	View	Create	Edit	Delete	Assign	Respond	Export	Approve	Scope
Schemes	Yes (list, detail)	Yes	Yes	Yes	Not Available	Not Available	Not Confirmed	Not Available	Yes
Users	Yes	Yes	Yes	Yes	Not Available	Not Available	Not Confirmed	Not Confirmed	Yes
Applications	Yes	Yes	Yes	Yes	Not Available	Not Available	Not Confirmed	Not Confirmed	Yes
Requests	Yes	Not Available	Not Available	Not Available	Yes	Yes	Not Confirmed	Not Available	Yes
Applicant Profile	Yes	Yes	Yes	Yes	Not Available	Not Available	Not Confirmed	Not Available	Yes
Role and Access	Yes	Yes	Yes	Yes	Not Available	Not Available	Not Confirmed	Not Available	Yes

Module	View	Create	Edit	Delete	Assign	Respond	Export	Approve	Scope
Designation	Yes	Yes	Yes	Yes	Not Available	Not Available	Not Confirmed	Not Available	Yes

Two observations follow. First, export and approval are not first-class permissions anywhere, yet both are capabilities the business is likely to delegate. Second, the requests module uses assign and respond instead of edit, so a generic “edit” grant will not enable helpdesk work.

15.2 Designation matrix

The master holds 32 seeded designations across six levels, with rank derived from list order. Live assignment counts are not computed anywhere in the code, so they are reported as Not available rather than estimated.

Level	Designation	Rank	Status	Assigned users	Source
State	President	1	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Vice President	2	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	General Secretary	3	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	General Secretary (Organisation)	4	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Secretary	5	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Treasurer	6	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Executive Member	7	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
Region	President	1	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	In-charge	2	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Coordinator	3	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Cluster In-charge	4	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
Organisational District	President	1	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Vice President	2	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	General Secretary	3	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	General Secretary (Organisation)	4	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Secretary	5	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Treasurer	6	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Executive Member	7	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
Mandalam	President	1	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Vice President	2	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	General Secretary	3	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Secretary	4	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Treasurer	5	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Committee Member	6	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
Area	Kendra Convener	1	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Area Coordinator	2	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Area In-charge	3	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Area Committee Member	4	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
Booth	President	1	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL

Level	Designation	Rank	Status	Assigned users	Source
	Secretary	2	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Committee Member	3	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL
	Worker	4	Active	Not available	DEFAULT_DESIGNATIONS_BY_LEVEL

The legacy register in party-workers.ts holds 30 entries across nine levels, including three levels that the master does not cover: assembly constituency, local body and organisational unit. Where the two registers overlap, names differ: the legacy register prefixes the level ("Mandalam President") where the master does not. A single authoritative register is required.

15.3 Access scope matrix

Scope selection is uniform across modules because it is generated from the same scope list. The table therefore records availability rather than a per-module design decision, and the empty column is the finding.

Module	Own records	Below my level	Same level (peers)	Above my level
Schemes	Selectable	Selectable	Selectable	Not exposed
Users	Selectable	Selectable	Selectable	Not exposed
Applications	Selectable	Selectable	Selectable	Not exposed
Requests	Selectable	Selectable	Selectable	Not exposed
Applicant Profile	Selectable	Selectable	Selectable	Not exposed
Role and Access	Selectable	Selectable	Selectable	Not exposed
Designation	Selectable	Selectable	Selectable	Not exposed

"Selectable" means the scope can be stored against a role. It does not mean the scope is applied when a list or record is served.

16 User Stories

Stories are written from the perspective of the actor who performs the work, not the developer. Priority follows MoSCoW.

ID	Story	Priority
US-01	As a state administrator, I want to create a role with a clear name and an explicit set of module permissions, so that I can delegate a defined job without granting everything.	Must
US-02	As a state administrator, I want to edit an existing role and see how many users it affects, so that I understand the blast radius before I save.	Must
US-03	As a state administrator, I want dependent permissions to be added and removed together, so that I cannot create a role that can edit but not view.	Must
US-04	As a state administrator, I want to deny a module to a role, so that a functionary cannot open a screen that is not part of their job.	Must
US-05	As a state administrator, I want to restrict a role to records below the holder's level, so that a district office does not see another district's work.	Must
US-06	As a state administrator, I want to create a designation at a specific organisation level, so that the post appears only where it belongs.	Must
US-07	As a state administrator, I want the designation list to filter by the level I selected, so that I cannot pair a booth post with a state user.	Must
US-08	As a state administrator, I want to assign one role to a user and change it later, so that a transfer does not require recreating the account.	Must
US-09	As a regional administrator, I want to move a user from one mandalam to another while keeping their role and designation, so that reorganisation does not break their access.	Should

ID	Story	Priority
US-10	As a state administrator, I want to revoke access immediately, so that a departing functionary cannot use a signed-in session.	Must
US-11	As a security reviewer, I want every unauthorised attempt to be refused by the server and recorded, so that I can investigate and prove compliance.	Must
US-12	As a district administrator, I want to create a role that uses only permissions I already hold, so that I cannot escalate myself or others.	Should
US-13	As an auditor, I want a history of who changed which permission and when, so that access decisions are accountable.	Should

17 Acceptance Criteria

Each criterion is testable as written. The final column records whether the current code satisfies it, which determines whether the item is a regression test or new work.

ID	Given / When / Then	Met today?
AC-01	**Designation filtering.** Given the actor selects an organisation level, when the designation list opens, then only active designations associated with that level are offered.	Yes
AC-02	**Module permission.** Given a user lacks view permission on a module, when they attempt to reach its route directly, then the request is refused and no data is returned.	No
AC-03	**Data scope.** Given a user holds own-records scope only, when a list is requested, then only records owned by or assigned to that user are returned.	No
AC-04	**Role permission update.** Given an authorised administrator changes a role, when the change is saved, then holders are subject to the new permissions on their next request.	No: cached session
AC-05	**Duplicate role.** Given a role named District Coordinator exists, when an administrator saves a role named district coordinator, then the save is rejected and the existing role is untouched.	Yes
AC-06	**Minimum content.** Given a role with no assignment level or no permission, when the administrator saves, then the save is blocked with a field-level message.	Yes
AC-07	**Prerequisite cascade.** Given edit is granted without view, when the grant is applied, then view is added automatically.	Yes
AC-08	**Prerequisite removal.** Given view is revoked while edit is held, when the revocation is applied, then edit and every transitive dependent are removed.	Yes
AC-09	**Designation level guard.** Given a booth designation is injected into a state user form, when the form is saved, then the save is rejected with an explicit message.	Yes
AC-10	**Level change.** Given a designation has been selected, when the organisation level changes, then the designation selection is cleared.	Yes
AC-11	**Duplicate designation.** Given a designation named Treasurer exists at Mandalam, when another Treasurer is created at Mandalam, then the save is rejected.	No
AC-12	**Delete with holders.** Given three users hold a designation, when the designation is deleted, then the delete is blocked or the holders are reassigned first.	No
AC-13	**Disabled designation.** Given a designation is disabled, when a user form is opened, then the designation is not offered but existing holders are unaffected.	Yes
AC-14	**Privilege escalation.** Given a district administrator holds only applications view, when they attempt to grant applications delete, then the grant is refused.	No
AC-15	**Revocation.** Given a role is removed from a user, when that user next requests a protected screen, then access is refused without waiting for session expiry.	No
AC-16	**Default deny.** Given no scope is configured for a module, when a record is requested, then access is denied rather than allowed.	No
AC-17	**Above-level scope.** Given above-level is not an available scope, when an administrator reviews the scope controls, then the scope does not appear as a selectable option.	Yes

ID	Given / When / Then	Met today?
AC-18	**Location persistence.** Given an administrator adds an area in the location master, when the page is reloaded, then the area is still present.	No
AC-19	**Audit.** Given any role or designation change, when the change succeeds, then an immutable audit record exists with actor, target, before and after.	No
AC-20	**Session expiry.** Given a session older than eight hours, when any admin route is opened, then the user is redirected to sign in.	Yes

18 Risks and Dependencies

ID	Risk	Likelihood	Impact	Mitigation
R-01	Privilege escalation: a delegated administrator grants permissions beyond their own	High	High	Server-side delegation ceiling evaluated against the actor's own grants
R-02	Designation-derived roles grant unplanned permissions	High	High	Remove automatic role synthesis; require explicit role assignment
R-03	Over-broad peer visibility exposes other districts	Medium	High	Define peers as same unit, not same level, pending approval
R-04	Cross-district data leakage through lists or exports	High	High	Row-level filtering at query time; export goes through the same filter
R-05	UI and backend enforcement diverge	High	High	Single policy module evaluated server-side; UI consumes the same decision
R-06	Stale permissions after a role edit	High	Medium	Stateless evaluation per request; no permission cache in the session
R-07	Users remain attached to deleted or disabled designations	Medium	Medium	Dependency check before delete; reassignment workflow on disable
R-08	Missing audit makes investigation impossible	High	High	Immutable append-only audit store with actor, target and diff
R-09	Incomplete hierarchy prevents scope calculation	High	High	Publish mandalam, area and booth masters with stable identifiers
R-10	Two level vocabularies cause mismatched assignments	High	Medium	One canonical level enumeration shared by role, user and designation
R-11	Location data lost on reload	Certain	Medium	Persist location master with the same rigour as roles
R-12	Local-storage tampering changes effective permissions	High	High	Server-authoritative permissions; browser holds no policy

18.1 Dependencies

- A server-side identity provider and session service, without which none of the enforcement requirements can be met.
- An agreed canonical organisation master covering state, region, revenue district, organisational district, mandalam, area and booth, with stable identifiers.
- A decision on whether revenue district and organisational district coexist or whether one is derived from the other.
- A data-ownership convention for every access-controlled record, so that scope can be evaluated.
- A retention and privacy position for the audit trail, including how long actor and subject identifiers are kept.

19 Gap Analysis

Priorities are Critical, High, Medium and Low. A gap marked Critical prevents production release of delegated administration. Confirmed defects are distinguished from enhancements in the recommendation column.

ID	Area	Current implementation	Expected behaviour	Priority	Recommendation
G-01	Server enforcement	No API or middleware; access is presentation only	Every route and data call authorises the actor	Critical	Defect. Build a policy module and call it on every request.
G-02	Persistence	Roles, users and designations live in local storage	Durable, transactional, multi-user storage	Critical	Defect. Move to a server data store with migrations.
G-03	Audit	No access audit exists	Immutable record of every access change	Critical	Defect. Append-only audit with before and after values.
G-04	Designation to role	22 system roles synthesised from designations	Designation never grants permission	Critical	Defect. Remove synthesis; migrate affected users to explicit roles.
G-05	Designation register	Three registers with divergent names	One authoritative master consumed everywhere	High	Defect. Consolidate and migrate.
G-06	Data scope application	Scopes stored but never evaluated	Scopes filter every query	Critical	Defect. Implement row-level filtering.
G-07	Above-level scope	Defined but hidden from both forms	Consistent vocabulary or complete removal	Medium	Enhancement. Decide and align model with UI.
G-08	Delegation policy	Two actors only; no district-level ceiling	Per-actor delegation ceiling enforced server-side	High	Defect. Extend policy to every administrative actor.
G-09	Role change propagation	No cache invalidation or re-evaluation	Next request reflects new permissions	High	Defect. Stateless evaluation per request.
G-10	Multiple roles	Single assignedRole string	Agreed model with explicit precedence	Medium	Enhancement. Decide whether multiple roles are required.
G-11	Designation validation	Name-only check; duplicates allowed	Unique within level; dependency-safe delete	High	Defect. Add uniqueness and dependency checks.
G-12	Location persistence	In-memory only	Persisted master with stable ids	High	Defect. Persist and model units as records.
G-13	Hierarchy coverage	Stops at revenue district plus a mapping	Full tree with mandalam, area and booth nodes	High	Defect. Publish canonical masters.
G-14	Level vocabulary	Two enumerations that disagree	One canonical enumeration	High	Defect. Merge models.
G-15	Export and approval	Not modelled as permissions	Grantable and enforced if the business needs them	Medium	Enhancement. Confirm requirement first.
G-16	Personal overrides	Per-user grid on the assignment screen	Either supported with audit, or removed	Medium	Enhancement or defect depending on decision D-03.
G-17	Role details view	Drawer only, no route	Addressable detail with holders	Low	Enhancement.
G-18	Booth data	Six generated booths per constituency	Official booth master	High	Defect. Replace placeholder with published data.

20 Recommendations

The sequence below protects the work already done. The data model, the permission catalogue and the matrix interface are sound and should be retained; what changes is where decisions are made and where state lives.

Phase	Action	Outcome
1. Freeze the model	Approve the four-concept separation, the seven-module catalogue and the three exposed scopes. Publish this document as the reference.	One agreed vocabulary before any code changes.
2. Move identity	Replace the local session with a server session and a real credential check. Keep the eight-hour policy if it suits operations.	Tampering with local storage no longer grants access.
3. Move policy	Port permissionModules, permissionPrerequisites and the delegation policy to a shared server module. Expose one authorisation call used by every route.	Single source of truth for allow and deny.
4. Enforce on data	Add unit and ownership fields to access-controlled records. Apply scope filters in every list, detail, export and approval path.	Visibility promises become true.
5. Remove the shortcut	Stop synthesising roles from designations. Migrate affected users to explicit roles after review.	Designation becomes organisational identity only.
6. Consolidate masters	Publish one designation register and one organisation master with stable identifiers, consumed by every screen.	No divergent names or lost locations.
7. Add audit	Write an immutable audit record for role, permission, designation and assignment changes, with a read-only viewer.	Decisions become accountable.
8. Delegate	Introduce per-actor delegation ceilings and a delegation console for regional and district administrators.	Administration scales beyond the state office.

20.1 What to keep

- The seven-module, twenty-nine-action catalogue with uneven action sets, which reflects real job shapes rather than a generic CRUD template.
- The prerequisite graph and its bidirectional cascade, which prevents the most common misconfiguration.
- The per-module scope column, which allows a role to read widely but edit narrowly.
- The level-first designation picker with an explicit cross-level guard on save.
- The separation of an organisation level field from a designation field on the user record, which is the foundation the rest of the model needs.

20.2 What to stop

- Storing policy in the browser, including a role literal in the session object.
- Deriving permission from organisational identity.
- Treating the settings workspace as implicitly available to every signed-in administrator.
- Maintaining parallel designation constants in three files.
- Reporting a data-access setting that no query honours.

21 Open Decisions

These items cannot be resolved from the code. Each needs a named owner and a decision date before the corresponding requirement can be built.

ID	Decision required	Options	Owner	Blocks
D-01	Does a designation ever grant permission?	Never; or only through an explicit, separately approved mapping	State administration	G-04, FR-06
D-02	What does “below my level” include?	All descendants; or direct children only	Product and state administration	G-06, R-03
D-03	Are per-user permission overrides permitted?	Allow with audit; or remove the grid	Security and product	G-16
D-04	What does “peers” mean?	Same unit; or everyone at the same level statewide	State administration	G-06

ID	Decision required	Options	Owner	Blocks
D-05	Can a user hold more than one role?	Single role; or multiple with precedence rules	Product	G-10
D-06	Is above-level visibility ever legitimate?	Remove the scope; or expose with approval workflow	Security	G-07
D-07	Do revenue and organisational districts coexist?	Both, linked; or organisational derived from revenue	Organisation	G-13, G-14
D-08	Are export and approval permissions required?	Model them now; or defer with a documented gap	Product	G-15
D-09	How long is audit retained and who may read it?	Policy decision	Compliance	G-03
D-10	Which office owns designation naming?	State office; or distributed with review	State administration	G-05

22 Appendix — Source Code References

Every claim in this document is traceable to the files below. Paths are repository-relative. Symbols are named exactly as they appear in the source. No line numbers are cited, because they change; the symbol is the stable reference.

File	Symbols inspected	What it evidences
src/data/party-workers.ts	permissionModules, permissionModulesBase, permissionPrerequisites, withPrerequisites, withoutDependentPermissions, rolePresets, assignmentLevels, roleOrganisationLevels, partyDesignations, delegationPolicies, canDelegateAction, scopeTypeOptions, partyRegions, AccessGrant, hasScopedAccess	Permission catalogue, prerequisites, presets, designations, delegation, scope vocabulary and the shared evaluator
src/data/role-management.ts	ManagedRole, RoleDraft, DataAccessScope, dataAccessOptions, scopedPermissionKey, allScopedPermissionKeysWithExtras, builtInManagedRoles, partyDesignationManagedRoles, loadManagedRoles, saveManagedRoles, managedRoleStorageKey, deletedManagedRoleStorageKey, customOrganisationLevelStorageKey, customDesignationStorageKey	Role and scope types, storage adapters, designation-derived role synthesis
src/components/admin/ RoleAccessSettings.tsx	RoleAccessSettings, ManagedDesignation, MANAGED_DESIGNATIONS_KEY, DEFAULT_DESIGNATIONS_BY_LEVEL, loadManagedDesignations, saveManagedDesignations, saveRole, handleSaveDesignation, handleToggleDesignationStatus, handleDeleteDesignation, MANAGED_USERS_KEY	The settings workspace, validation, role protection, designation lifecycle, user persistence
src/routes/ admin.settings_.new-role.tsx	dataAccessChoices, supportedScopedPermissionKeys, primaryMatrixColumns, handleSave	Full-page role form and the suppression of above-level scope
src/routes/ admin.settings_.new-user.tsx	ORG_LEVEL_OPTIONS, DESIGNATIONS_BY_ORG_LEVEL, getOrgLevelForDesignation, handleSave	User creation, level-first designation filtering, cross-level guard
src/routes/ admin.settings_.assign-role.tsx	primaryMatrixRows, secondaryMatrixRows, ROLE_OPTIONS, getMatrixColumnActionIds	Assignment screen, per-user overrides, role labels
src/routes/admin.settings.tsx	validateSearch, SettingsPage	Settings shell and tab parameters
src/routes/admin.tsx	ProtectedAdminRoute, isAdminAuthenticated	The only route guard in the application
src/lib/admin-auth.ts	ADMIN_SESSION_KEY, ADMIN_SESSION_DURATION_MS, createAdminSession, getAdminSession, clearAdminSession	Client-side session with the hard-coded STATE_ADMIN role
src/routes/auth.login.tsx	handleSubmit, DEMO_USERNAME, DEMO_PASSWORD constants	Credential comparison against hard-coded values

File	Symbols inspected	What it evidences
src/data/users.ts	AppUser, getUserDesignation, getUserRegion, ORG_DISTRICTS_MAP, getUserOrgDistrict	User shape, revenue to organisational district mapping, fallback resolvers
src/data/ admin-dashboard-metrics.ts	OrgLevel, orgHierarchyData	The configured hierarchy tree, which stops at revenue district
src/server.ts	default fetch handler, normalizeCatastrophicSsrResponse	SSR entry only; no authorisation
docs/ ADMIN-PROTOTYPE-AUDIT.md	Audit findings	Independent confirmation that the admin workspace is a client-side prototype

22.1 Verification statement

The following were confirmed by direct inspection: the absence of an API layer, database client, migration or server-side guard; the set of local-storage keys; the seven-module and twenty-nine-action catalogue; the twenty-one prerequisite declarations; the four scope definitions and the suppression of above-level; the thirty-two seeded designations across six levels and the thirty legacy entries across nine levels; the twenty-two designation-derived roles; the three regions, fourteen revenue districts and thirty mapped organisational districts; and the presence of an operational activity log that is unrelated to access audit.

Where a behaviour could not be located — server enforcement, audit of access changes, reporting relationships, ownership of records and persistence of the location master — this document says so rather than inferring it. Those statements are findings about the absence of implementation, not opinions about design.

End of document

Vikasita Keralam, Role, Access and Designation: Business Requirements, Workflows and Information Architecture. Reference VK-BRD-RBAC-001, version 1.0, issued 13 November 2026. Findings reflect the repository at the time of analysis and should be re-verified before implementation begins.